

OAuth 2.0

1. Explain the difference between authentication and authorization.

Answer:

Authentication: Verifying who a user is (e.g., logging in with a password or Biometrics). For example showing your ID at a building entrance.

Authorization: Verifying what a user is allowed to do (e.g., can this user edit this file?). For example keycard that only opens specific doors inside that building.

2. Why is OAuth 2.0 needed when JWT already exists?

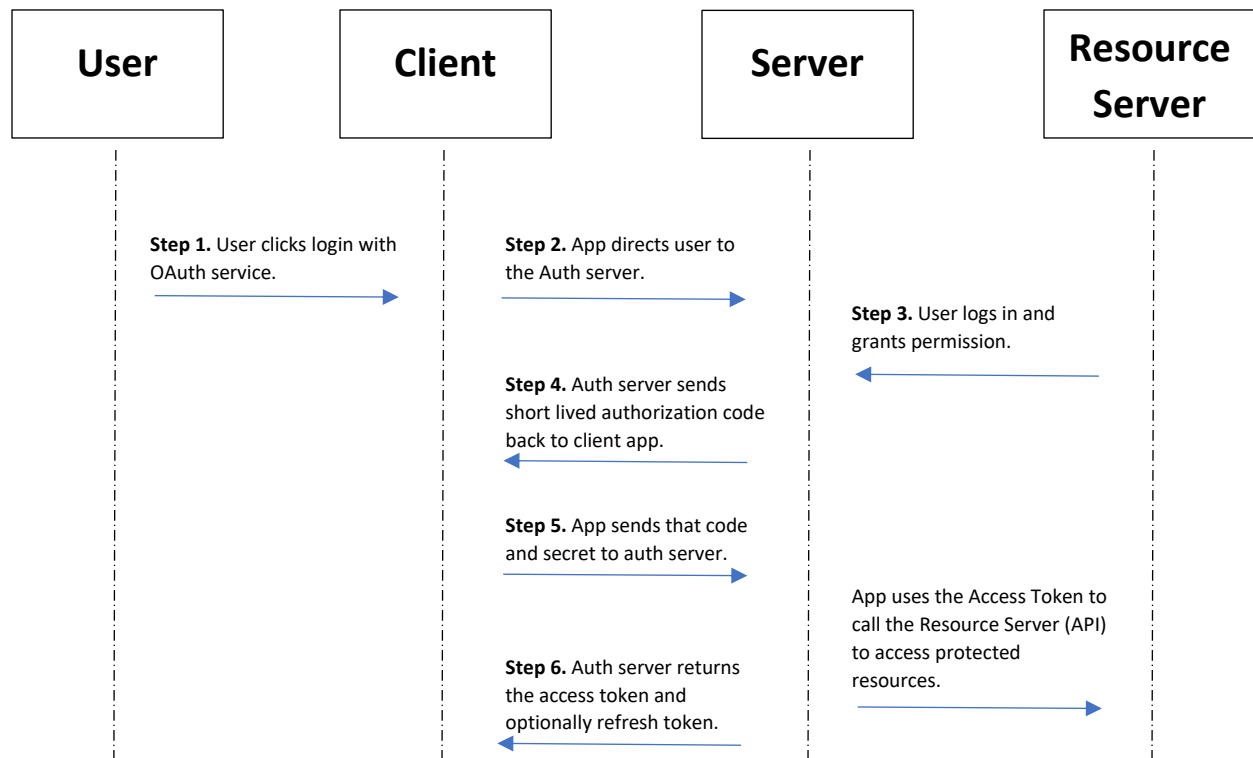
Answer:

JWT (JSON Web Token): It is a format. It's a way to package information (claims) into a signed string.

OAuth 2.0: It is a framework/protocol. It defines the steps between a user, an application, and a server to grant access without sharing passwords.

Real world example: JWT is the physical passport; OAuth 2.0 is the international law and process for how airports verify and stamp that passport.

3. Describe the OAuth 2.0 Authorization Code flow with a clear diagram.



4. Explain the following concepts: - Access Token - Refresh Token - Token expiration and renewal.

Answer:

Access Token: Short-lived (minutes/hours). Used to access protected resources.

Refresh Token: Long-lived (days/weeks). Used to get a new Access Token without the user having to log in again.

Renewal: The process of using a Refresh Token before the Access Token expires to maintain a seamless user session.

5. Compare OAuth 2.0 and JWT. Explain their relationship and how they work together in modern web applications.

Answer:

OAuth 2.0 doesn't strictly require JWTs, but in modern applications, the Access Token issued by an OAuth server is almost always a JWT. They work together: OAuth provides the secure handshake, and JWT provides the portable, verifiable payload.